16 Laravel 12 Security – How to Harden the Web App

16.1 Introduction

Web application security is a fundamental aspect of modern development, especially when applications manage sensitive data or are exposed to the public internet. Laravel 12 offers a comprehensive set of built-in security features, but developers must understand and implement best practices to ensure complete protection against threats like SQL injection, XSS, CSRF, and more. This chapter guides you through practical techniques to harden your Laravel application.

16.2 Understanding Common Threats

Before implementing security measures, it's important to understand the types of threats web applications commonly face. The OWASP Top 10, https://owasp.org/www-project-top-ten is a globally recognized list of the most critical security risks.

Laravel helps mitigate many of these by default, but developers still play a key role in securing the application through proper usage and configuration.

16.3 Cross-Site Scripting (XSS) Protection

XSS attacks occur when attackers inject malicious scripts into web pages. Laravel protects you by automatically escaping output in Blade templates:

```
<!-- Safe: Escaped output -->
{{ $username }}

<!-- Unsafe: Raw output -->
{!! $username !!}
```